Secure, Safe, Fast Linux Hosting v 1.6.0

copyright 2008 - 2011
www.waltercedric.com
Security is a Journey Not a Destination

Anomaly detection

- FAF file anomaly finder
  - report unusual change of files
  - generates audit reports
  - http://rfxnetworks.com/faf.php
- secheck
  - secheck is a script which imitates currently existing log checkers but with a focus on security. secheck does some basic system security checking, then emails to output to a given user.
  - openBSD scripts
  - run opensuse/debian also
  - use YaST to install
- antivirus
  - virus database update auto in crontab
  - FREE for personal use
    - avg 8.5
      - command
        - avgscan /
      - download
    - Clamav
    - F-PROT
      - download
      - command
        - fpscan -a -b -y -s 4 /
- server health
  - http://www.rfxnetworks.com/sim.php
    - get emails, cpu memory status
    - restart if need some components
    - read more HERE

Keep system secured

- Limit access
  - ssh
    - only public private key login
  - monitor brute force attempt with sshdfilter
    - http://www.csc.liv.ac.uk/~greg/sshdfilter/
- Block access
  - firewall
    - A Stateful Packet Inspection (SPI) firewall, Login/Intrusion Detection and Security application
    - CSF
      - http://www.configserver.com/cp/csf.html
      - read more HERE
  - block ftp server
    - use secure copy instead
      - winscp
- Maintenance policy
  - Keep all softwares always up to date
    - linux rpm package
    - PHP
    - MYSQL
    - as root
      - debian
        - apt-get update
      - opensuse
        - zypper up
      - redhat
        - yum update
- Monitoring

Iterative process

- fix objectives
  - so many readonly users in system
  - so many registered users open sessions
  - best response time X in seconds
- load system
  - record testcases
  - Apache JMETER
    - create virtual users to simulate load
- measures
  - quality! ⚠
  - better
  - worse
    - rollback changes
- small changes
  - first software changes, you can win a lot there and its cheap
  - last infrastructure changes
  - you may want to increase server memory
    - cheap today
    - may work

software changes

- Apache
  - modules
    - mod_deflate
      - PHP can also zip response but not very efficient
      - cpu cost vs bandwidth
      - read more HERE
    - mod_expires
      - set expire header on files, pics, js
      - tell the browser to not request file before xx days/months
      - read more HERE
      - apache mod_expires.conf
    - mod_header
      - apache mod_header.conf
    - mod_pagespeed
      - optimize HTML on the fly and save in a cache
      - apply most of Yahoo YSLOW rules automatically
      - avoid optimizing manually Joomla! Drupal, Wordpress sites
      - read more HERE
    - reduce DNS lookup
    - hotlinking
      - disable cpu, bandwidth stealing
      - read more HERE
- PHP
  - Install PHP Opcode cache
    - file based
    - memory based
      - APC
        - advanced PHP cache
        - use by wikipedia
        - 100% more output speed
        - read more HERE
- Mysql
  - configuration tuning
    - Use tuning-primer.sh
    - buffer, settings in my.ini
    - allocate more buffer to select, join, sort operations
    - use innodb engine (transactionnal row locking) where it make sense per table
    - prefer mylsam (transactional table locking)
    - use memory base table for sessions tables
  - monitoring
    - look at slow queries
    - quality of schema, index missing
      - use explain query
    - look at full table scan
      - use explain query
        - add index
  - *crontab*
    - optimize tables and index on purpose
      - per day, week
      - mysqlcheck -op -u user_name --all-databases
    - rebuild statistics
- webpages
  - less js, css, images include
  - reduce content size in xhtml
    - space
  - use CSS-Sprite
    - use this nice tool sprite me
  - Best Practices for Speeding Up Your Web Site

infrastructure

- mutiple apache
  - expensive $$$$ €€€€
  - one tuned for static content, gif, zip, html, pdf
  - one for dynamic php, perl
- multiple database server
  - tuning, allocate more buffer
  - complex, costly
- memcache
- ideas
  - Wikipedia Architecture
  - ebay infrastructure
  - drupal high performance forum
- Use CDN
  - a network of servers containing copies of data placed at various points in a network all over the world that maximize bandwidth / speed access to the data for users
  - are expensive but
  - Google let you use their CDN for all AJAX library (jquery more than 80KB, mottols the same size)
    - ex: http://ajax.googleapis.com/ajax/libs/jquery/1.2.6/jquery.js
    - read more HERE
  - search for other "offload asset" in google
- server settings
  - No energy saving!
    - some hosting provider compile their own kernel and are agressive on energy saving
    - check cpu speed
      - cat /proc/cpuinfo
      - cpufreq-info
    - check max accepted
    - full speed all the time
      - cpufreq-set -c 0 -d 2GHz

Joomla

- remove (deinstall)
  - uneeded components
  - uneeded modules
  - less code less security threat more speed
- Remove unnecessary content
  - remove unecessary modules, plugins, components
- use Joomla 1.5 and APC for caching
  - alternatively use com_pagecache
- less rights, do not use apache user as owner, and group
  - maintenance is difficult
- visit Joomla! performance forums

Worth Reading

- Best Practices for Speeding Up Your Web Site

Getting more Speed

Intrusion detection

- *crontab*
  - Possible Exploit Script Report
    - scan files with regex after pattern
    - r0nin|m0rtix|r57shell|c99shell|phpshell|void\.ru|phpremoteview|directmail|bash_history|\.ru/|brute *force|MultiViews|cwings|bitchx|eggdrop|guardservices|psyBNC|DALnet
  - File Anomaly Detection
    - generates audit reports for data matching specific characteristics
    - read more HERE
  - every 4 hours send an email with results to admin
- Useful bash commands
  - listOpenConections
    - lsof -i
  - listinternetconnection
    - netstat -lptu
- Rootkit detection
  - rkhunter
    - check for rootkit periodically
      - everyday at 1AM
      - 0 1 * * * nice -n 19 /usr/local/bin/rkhunter --checkall 2>&1 | mail -s "rkhunter output" youremail@gmail.com
    - too late if alarm
    - read more HERE
  - chkrootkit
    - check for rootkit periodically
      - everyday at 1AM
      - 0 1 * * * nice -n 19 /sbin/chkrootkit 2>&1 | mail -s "rkhunter output" youremail@gmail.com
    - too late if alarm
    - read more HERE
  - tripwire
    - extreme but secure
    - hash every file on filesystem
      - detect file tampering
    - keep hash database secure for further equality check on safe medium: NOT ON SERVER

Backup

- *crontab*
  - daily/weekly/monthly database backup
    - automysqlbackup.sh
      - create email google account
      - get an email daily of database content
      - read more HERE
  - tar and FTP the result
- MySQL
  - backup
    - daily, weekly
    - use automysqlbackup.sh to receive daily mail with mysql data

Apache

- modules
  - mod_evasive
    - escape denial of service attack
    - limit number of requests per seconds for an IP
    - read more HERE
  - mod_security
    - WAF kind of software firewall
    - based on regular expressions analyse requests and responses and block if needed
    - predifined rulesets
      - www.gotroot.com
      - www.modsecurity.org
    - you must fake apache signature: NOYB
      - none of your business
    - read more HERE
  - mod_php
    - to avoid
      - php script run with apache user
      - php script can change files across clients on server
      - only one php.ini for all domains and users
      - only one php version
  - use mod_fcgi instead
    - php scripts run with user rights
    - per client/user/directory a php.ini
    - run php4 and php5 in same apache
    - run != php version per directory
- remove uneeded modules
  - golden rule: less code less vulnerability
    - vi /etc/sysconfig/apache2
- server-tuning.conf
  - tuning
    - worker is better but only if php fastcgi as mod_php not multithreaded
    - forked with mod_php, use more memory
  - use threading model not forked
    - only with php fastcgi
- http.conf tuning
  - set
    - Timeout 20
    - KeepAliveTimeout 2
    - HostnameLookups off
    - KeepAlive Off
  - more? google
- htaccess
  - in some directory
  - not really secure

More security

- file system
  - correct owner and group
    - example: user cedric in group www-data
  - Use ONLY Correct permissions
    - the less right the better
      - 0600 PHP Scripts
      - 0755 Non-PHP Scripts (*.cgi, *.pl, *.pm, *.py, *.e)
      - 0644 Non-Script Files (Images, CSS, HTML, Templates, Etc)
      - 0755 All Folders (Any folder you would find below public_html)
    - NEVER chmod 777
    - fix permissions automatically
      - files
        - alias fixpermF='find . -type f -exec chmod 644 {} \;'
      - directories
        - alias fixpermD='find . -type d -exec chmod ago=+rx {} \;'
      - if stable (just db changes, images); make it read only in httpdocs
        - find . -type f -exec chmod 444 {} \; find . -type d -exec chmod 555 {} \;
  - Apache must refuse acccess to files with too much permissions
  - Searching for modified files on the server
    - check files permissions often
    - use FAF file anomaly finder
- passwords
  - NEVER EVER REUSE ANY PASSWORD
    - passwords MUST BE UNIQUE per services, functions
      - ex: mysql password = ftp password = joomla! password
  - not human readable + not based on dictionnary
  - generate them at least 128 bits with all character
    - see KEEPAS or equivalent for maintaining
    - Ex: -S=,b5BOr%:JDWTp6Gs%na
    - Use Upper-Case+Lower-Case+Digits+Minus+Underline+Special
    - At least 22 characters!
- PHP
  - compile your own php
    - use hardened PHP patch
      - http://www.hardened-php.net/
    - remove unused library
  - Do not use PHP4, end of life since 2008!
  - php.ini
    - register_globales = off
    - allow_url_fopen = off
    - file_uploads = off
    - display_errors = off
    - expose_php = Off
      - ; Decides whether PHP may expose the fact that it is installed on the server ; (e.g. by adding its signature to the Web server header). It is no security ; threat in any way, but it makes it possible to determine whether you use PHP ; on your server or not.
    - disable SAFE_MODE
    - disable functions
      - show_source
      - system
      - popen
      - proc_open
      - phpinfo
        - dont give info to outside world
      - exec
      - passthru
      - shell_exec
      - file_open_base
        - set to http root to avoid path transversal attack
          - ubuntu /var/www/vhosts:/tmp
          - opensuse /srv/www/vhosts:/tmp
      - example
        - disable_functions = system, exec, shell_exec, passthru, set_time_limit, error_log, ini_alter, dl, pfsockopen, openlog, syslog, readlink, symlink, link, leak, fsockopen, popen, escapeshellcmd, apache_child_terminate apache_get_modules, apache_get_version, apache_getenv, apache_note,apache_setenv,virtual, proc_open, phpinfo, passthru, show_source

Load Tests

- Load produce per page is based on
  - user interaction: their speed (think time) and behaviour
  - size of page
    - number of static element
      - images
      - css
      - files
      - DNS lookup for external embeded file
    - business logic
    - shared ressource
  - database access
- Use a tool to create virtual users
- Many tools on the market
  - I like webperformance suite
  - Apache JMETER is free
- apache

Crash - Kernel Panic

- Check Content of
  - vi /var/log/warn
    - Look for entries that fall within the period of crashes. If entries show an incorrect software configuration, or the crash is systemically related to a service, or exhibit other unexpected behavior? If you find relevant entries that has been caused due to an incorrect software configuration, then make sure that the affected software (service / application) is configured correctly. The log files of the service or application may also contain additional information about the cause of an incorrectly configured software. If you find an entry that is provided with the classification EMERG, a system-critical event occurred. A system-critical event may be responsible for the crash of the server.
  - Browse the messages that were logged during the last boot, for entries that point to an error.
    - dmesg | grep [Ee]rro
    - dmesg | grep [Dd]efect
    - dmesg | grep [Ff]aul
    - dmesg | grep [Nn]o
    - dmesg | grep [Ff]ail
    - dmesg | grep [Ii]ncorrect
    - dmesg | grep [Bb]ad